Ministry of Higher Education
Colleges of Applied Sciences
The Information Technology Program

Final Exam

Academic Year: 2018-2019 **Semester: FALL** **Copy: A**

Course Code: ITDR2108 **Date: 03/01/2019**

Course Title: Introduction to Security **Time: 08:15 AM**

College: Ibri [x] Rustaq [ ] Salalah [ ] Sohar [ ] Sur [ ] [ ] Nizwa

Student Name: _____

Student ID: _____ **Group No.**_____

Instructions for students:

This exam lasts for **2 hours** and is worth **50%** towards your final mark for **ITDR2108**
Please, place all bags, folders and other belongings at the front or back of the room.
TURN OFF all mobile phones and leave them at the front or back of the room.
DO NOT TALK during the exam without permission from the invigilators.
Use **PEN** only to write your answers. **Calculator** is allowed.
Hand in the exam paper back to your invigilators at the end of the exam.

For Examiner use only:

Sections	Marks	Marks Scored							
A: MCQs	**10**								**A total**
B: Short Answers	**20**	B1	B2	B3	B4	B5	B6	B7	**B total**
C: Long Answers	**20**	C1		C2		C3			**C total**
Total	**50**								

Examiner: …… Signature ……..…..…….

Checked by: ……...……..…… Signature ……..……..……..

MULTIPLE CHOICE ANSWER SHEET:

	a	b	c	d
Q1	o	●	o	o
Q1	O	X	o	●

***Please mark your answers on the matrix below.**

Example **If you think the correct answer for Q1 is "b"**

If you change your mind to "d"

Q1	**a**	**b**	**c**	**d**	**Q2**	**a**	**b**	**c**	**d**	**Q3**	**a**	**b**	**c**	**d**	**Q4**	**a**	**b**	**c**	**d**
	O	**O**	**O**	**O**		**O**	**O**	**O**	**O**		**O**	**O**	**O**	**O**		**O**	**O**	**O**	**O**
Q5	**a**	**b**	**c**	**d**	**Q6**	**a**	**b**	**c**	**d**	**Q7**	**a**	**b**	**c**	**d**	**Q8**	**a**	**b**	**c**	**d**
	O	**O**	**O**	**O**		**O**	**O**	**O**	**O**		**O**	**O**	**O**	**O**		**O**	**O**	**O**	**O**
Q9	**a**	**b**	**c**	**d**	**Q10**	**a**	**b**	**c**	**d**										
	O	**O**	**O**	**O**		**O**	**O**	**O**	**O**										

<u>Section A Multiple Choice Questions:</u> (10 questions*1 mark=10)

Choose the correct answer for all of the following questions. You must mark your final answers in the provided grid.

1. Denial of service attack is a breach of _____
   a. Confidentiality
   b. Availability
   c. Integrity
   d. Authenticity

2. When you perform an online transaction with muscatmarket.com using your VISA card, it asks for the verified by visa (VBV) password. After checking the password, the system will send an OTP code to your mobile phone. To complete your transaction you need to enter the OTP code you received .Which type of authentication is used here?
   a. Multifactor Authentication
   b. Single-Factor Authentication
   c. Mutual Authentication
   d. Biometric Authentication

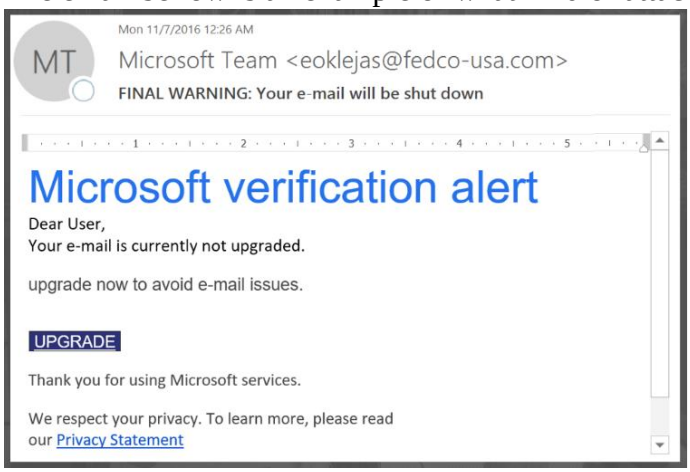
3. The set of permissions (d rw- r- - r-x) is interpreted as _____
   a. File, user(read/write), group(write),other(read)
   b. File, user(read/execute), group(read),other(read)
   c. Directory, user(read/write), group(read),other(read, execute)
   d. Directory, user(read), group(write),other(read)

4. _____is a reactive tool, in that it allows us to view the record of what happened after it has taken place
   a. Software patching
   b. Penetration testing tools
   c. Auditing
   d. Logging

5. Your organization uses several different types of cryptographic techniques. Which of the following techniques uses a private key and a public key (asymmetric encryption) ?
   a. RSA
   b. AES
   c. MD5
   d. RACE

6. _____is the state or condition of being free from being observed or disturbed by other people.
   a. Accountability
   b. Confidentiality
   c. Privacy
   d. Authenticity

7. The email bellow is an example of what kind of attack?



a. Pretexting
b. Phishing
c. Tailgating
d. MITM

8. What type of physical access control might we put in place in order to block access to a server room?
   a. Administrative
   b. deterrent
   c. Detective
   d. Preventive

9. Which one of the following port number is reserved for DNS service?
   a. 51
   b. 53
   c. 55
   d. 57

10. Which of the following tools is used to improve application security?
   a. Ping
   b. NMAP
   c. Fuzzer
   d. Metasploit

<u>Section B Short Answers:</u> (20 Marks: 5X4 Marks each)
Answer 5 questions ONLY. If you answer more than 5 questions, the first 5 questions will be marked.

B1. Classify each of the following attack situations to one of the main attack types (interception, interruption, modification, fabrication). (8*0.5=4 Marks)

The situation	The type of attack
Change system configuration	
Cutting communications line	
Unauthorised access to stored information	
adding a record to a database	
Deletion of a software	
sniffing	
Changing a value in a database.	
counterfeit bank notes	

B2. a. What is password Broute-force cracking?

b. propose one measure to prevent password Broute-force cracking .

B3. Explain the difference between DAC and MAC models.

B4. Explain how public-key cryptography and hash function can be used to provide confidentiality, authenticity, and integrity services to a communication channel.

B5. What is password syncing? List three different ways to enforce user to create a strong password.

B6. List the two main categories of IDSs methods of detecting attacks. Briefly explain each

B7. Name and define the two main categories of Web attacks.

<u>Section C Long Answer:</u> (20 Marks: 2X10 Marks each)

Answer Two questions ONLY. If you answer more than 2 questions, the first 2 questions will be marked.

C1. Answer the following questions

a. Compare between Business Continuity Planning (BCP) and Disaster Recovery Planning (DRP). (2 marks)

	Business Continuity Planning (BCP)	Disaster Recovery Planning (DRP).
Definition		

b. Name the three main categories of assets in which we are typically concerned with physical security. List two examples of threats for each of asset.(3 marks)

c. Read the following scenario and answer the following questions.

"Assume you do your initial backup on Monday, this first backup will contain your entire list of files and folders in your backup job. On Tuesday, at the next backup run, the entire list of files and folders will be copied again. On Wednesday, the entire list of files and folders will be copied again and the cycle continues like this. At each backup run, all files designated in the backup job will be backed up again. This includes files and folders that have not changed."

1. **From the above scenario, what type of backup has been used in the above scenario? (1 mark)**

2. **How grandfather-father-son backup system works? Explain your answer using a table? (4 marks)**

C2. Answer the following questions:

a. **An application vendor has just developed their new application; the organization has poor control to access their source code and lake to any security policy of how source code is handled exactly. Explain how the vendor can protect their source code from being exposed to an attacker or competitors using OPSEC process. (3 marks)**

b. What is the data foundation focus of the OPSEC? (2 marks)

c. Explain why we should not implement the same security level for the elements. (2 marks)

d. List and explain the three Haas' laws. (3 marks)

C3. Answer the following questions:

a. **What is Operating System Hardening? (2 marks)**

b. **How to terminate a running process with a process ID: 124567/java in a Linux OS. (1 mark)**

c. **Explain how ASLR (Address Space Layout Randomization) defenses against buffer overflow attacks. (1 marks)**

d. **List and explain six main ways to decrease operating system attack surface. (6 marks)**

-END OF EXAM-